

Plan 07 — Is detection real?

An offline-first re-test of the memory-signal spine

Comprehensive experimental-design handout · June 2026

- | | |
|--|---|
| 1. Summary | 8. Two modelling paths |
| 2. Motivation: what led here | 9. The separability ladder |
| 3. Research questions | 10. Two detector flavours, and the bake-off |
| 4. How we look at the data | 11. Methodology and statistical protocol |
| 5. Plan overview | 12. Expected results |
| 6. Metrics: existing and new | 13. Risks and honest scope |
| 7. Tests: what we have and what to capture | |

1. Summary

This handout specifies **Plan 07**, an offline-first re-examination of the central claim of this thesis. Plans 05 and 06 concluded that the VM memory signal (APF) supports **characterization, not detection** -- that no single channel separates malicious from benign behaviour. A reconvened review (a seven-role research team plus a three-lens adversarial critique, all reading the committed code) found that this negative may be an artifact of the **estimator and the small sample**, not a property of the signal.

Two facts, already sitting in our committed results, motivate the re-test. First, a **one-class novelty detector** (trained on benign only) scores **ROC-AUC 0.925** on a held-out workload and **0.933** on a held-out benign family -- far above the supervised classifier (~0.79) on which the 'detection is dead' conclusion rested. Second, the two workloads we called 'memory twins' (the stealth threat **slowburn** and the benign **pagefault**) are in fact **separable in the raw signal** (Cohen's $d \sim 5.6$, non-overlapping) yet both score **0.0** under leave-one-workload-out -- a labelling artifact, not aliasing.

Every decisive experiment runs **offline on data we already have**; new captures are gated behind an offline pilot. The outcome is win/win: either the thesis spine upgrades from a negative to a **positive, mechanistic** claim (with error bars), or the negative is **rigorously hardened** and its true limiter named. This document covers the research questions, the data model, the metrics (existing and new), the tests we have and the ones to capture, the two modelling paths, the methodology, and the expected results.

Dataset at a glance

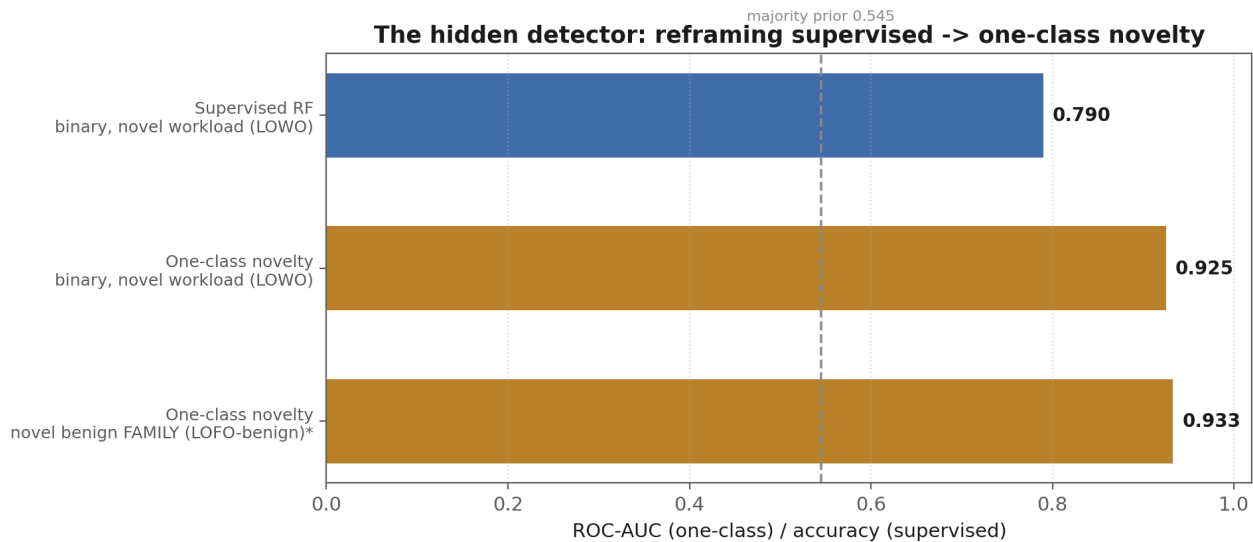
11 workloads, 5 families, 66 cells = 11 workloads x 3 durations (120 / 300 / 600 s) x 2 repetitions.
Memory snapshot cadence 500 ms; analysis window $W=8$, hop $H=4$; 5--244 windows per cell. Binary majority prior 0.545; family majority prior 0.364.

2. Motivation: what led here

APF (Active Page Fraction) is the fraction of 4 KB guest memory pages that change between two consecutive snapshots -- one number per snapshot, measured host-side with no guest agent. Plans 01--04 built and locked the capture pipeline; Plan 05 relieved a degrees-of-freedom starvation problem and ran a full 66-cell campaign; Plan 06 added a second, disk-I/O channel.

The downstream conclusion was sobering and honest: a **supervised** threat/benign classifier did not generalize to unseen workloads or families (binary leave-one-workload-out ~0.79, leave-one-family-out ~0.58, and 0.0 on the stealth pair), and the disk channel helped **characterization** (instance identification rose to 0.985) but not detection. Hence: characterization, not detection.

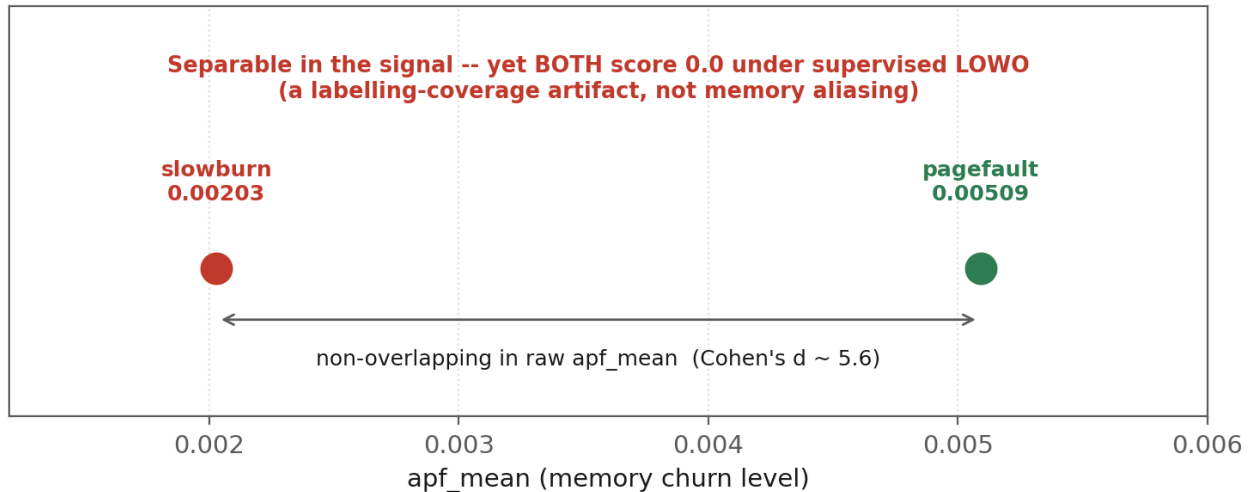
The review then noticed what the supervised framing had hidden. The **same committed results file** contains a one-class novelty detector at ROC-AUC 0.925 / 0.933, and the 'memory twins' separate cleanly in raw apf_mean. In other words, the negative result may be a property of **how we asked the question** (a supervised boundary across too few workloads), not of the memory signal. Plan 07 tests exactly that.



* LOF LOFO-benign 0.933 flagged INVALID (k=10 neighbours > 6-cell app family); re-run with k capped.

The motivating result. A one-class novelty detector already beats the supervised classifier the thesis used to declare detection dead. The 0.933 is flagged for a fixable validity issue (see Methodology).

The 'memory twins' are not twins



The 'memory twins' are not twins: slowburn and pagefault are non-overlapping in raw apf_mean, yet the supervised classifier scores both at 0.0 under leave-one-workload-out -- a labelling-coverage artifact.

3. Research questions

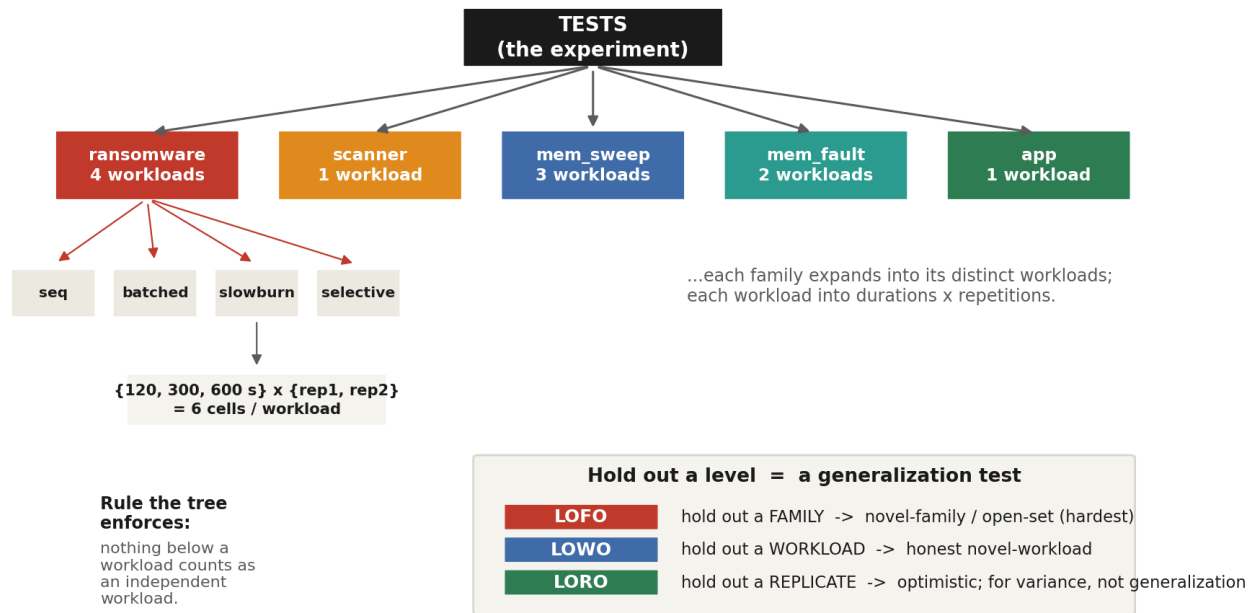
Plan 07 is organised around five questions. None is assumed; each is answered by an experiment whose every outcome is a publishable finding.

- **RQ1 -- Is detection real?** Does a one-class novelty model detect threats from memory (with honest error bars and a stated operating point), or was the high number a metric/prevalence illusion?
- **RQ2 -- Does memory separate the 'twins'?** Can a calibrated model separate slowburn from pagefault in memory alone, out-of-sample -- which would rewrite the characterization-not-detection spine?
- **RQ3 -- Are families cohesive, and does memory respect our taxonomy?** Do the workloads of a family resemble each other in memory (so a family-normal model is meaningful), and do data-driven clusters recover the semantic families or carve them differently? Cohesion is **measured**, not assumed; both answers are findings.
- **RQ4 -- Do magnitude-aware metrics catch stealth?** Does mean-Hamming-per-changed-page expose an encryptor (slowburn) that APF's changed-page count cannot see?
- **RQ5 -- How cheap can capture be?** What is the minimum useful trace length, and how coarsely can we sample, before the signal degrades -- which sets the budget for expanding the workload set?

4. How we look at the data

The experiment is built on a **nested data model**. Each level is both a statistical unit and a cross-validation protocol, and the structure enforces the rules that protect us from false confidence.

The nested data model



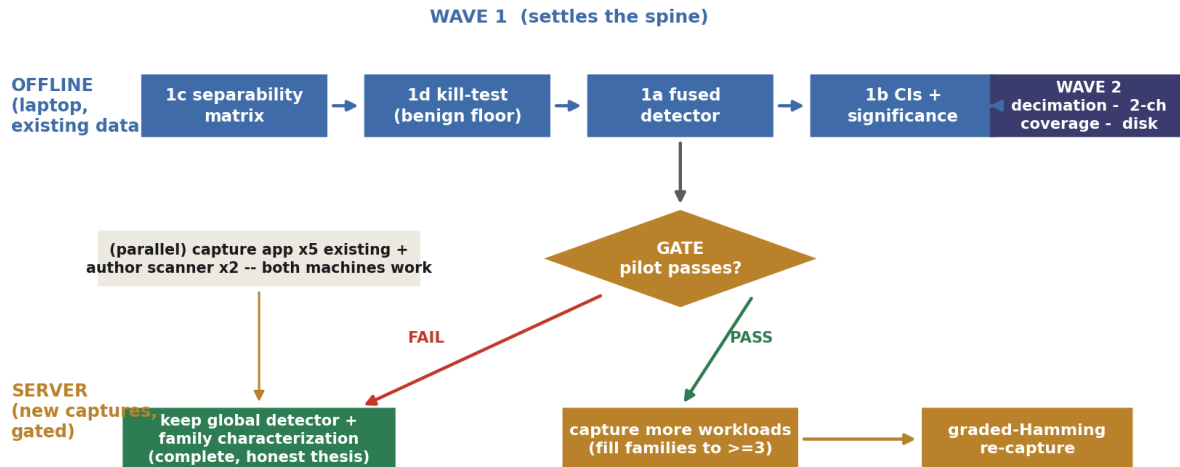
The nested data model and how holding out each level maps to a cross-validation protocol of increasing honesty.

The binding rule the tree makes explicit: **nothing below a workload counts as an independent workload.** Repetitions and analysis windows characterise within-workload variance (they matter precisely because the signal is stochastic -- scheduler, memory layout, cache and host noise vary run to run), but a generalization claim must hold out a whole workload (LOWO) or a whole family (LOFO). Duration is a controlled within-workload factor; a repetition is within-(workload, duration) noise.

5. Plan overview

Work proceeds on two tracks in parallel -- offline analysis on data in hand, and (gated) new captures on the server -- across three waves. A single decision gate governs whether any server time is spent.

Plan overview: two tracks, three waves, one gate



schematic

Two tracks, three waves, one gate. Wave 1 (offline) settles the spine; the gate releases server captures only if the offline pilot passes; either gate outcome leaves a complete, honest thesis.

Wave 1 (offline, existing data) -- run in order

- **1c separability matrix** -- the diagnostic: which behaviours actually alias in memory.
- **1d kill-test** -- the benign-floor learning curve; the cheapest test that could falsify the whole detection reframe before we over-invest.
- **1a fused detector** -- the definitive one-class experiment with PR-AUC, a leak-free operating point, per-workload recall, and a magnitude-vs-shape ablation.
- **1b confidence intervals + significance** on every remaining headline number.

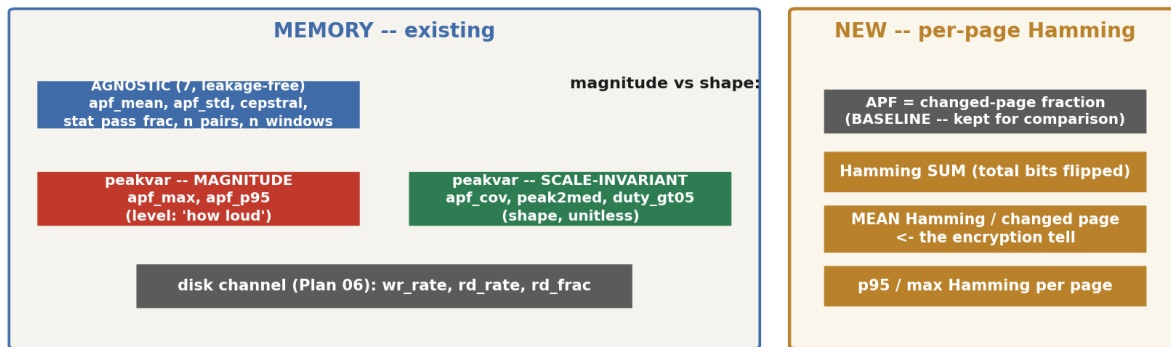
Wave 2 (offline) and Wave 3 (server, gated)

- Wave 2: the decimation cadence law, a two-channel alias-coverage statistic, and a disk-fairness re-analysis -- all offline.
- Wave 3: capture more workloads to lift the small families, and (if justified) a graded-Hamming re-capture -- only after the gate passes.

6. Metrics: existing and new

The features split into level (magnitude) and shape (scale-invariant). The strong one-class detector leans on magnitude features, which is also its weakness: magnitude is a poor proxy for threat in this corpus (the stealth threat slowburn is *quieter* than the benign mmap is loud). Plan 07 therefore tests magnitude, scale-invariant, and combined feature sets, and adds a new magnitude-aware-but-cheap metric.

Feature taxonomy: what we measure (old) and what we add (new)



Why the new metric: a stealth encryptor changes FEW pages (low APF -> looks quiet)

but each touched page is fully encrypted -> ~half its bits flip. APF cannot see this; mean-Hamming-per-changed-page can.

Computed additively at capture (XOR + popcount in the same page comparison APF already does) -> a few cheap scalars, no per-page storage.

The feature taxonomy. Existing memory and disk features (left) plus the new per-page Hamming scalars (right), with the motivation for the new metric.

Metric	Group	Status	What it captures
apf_mean, apf_std, cepstral, stat_pass_frac, n_pairs, n_windows	AGNOSTIC (7)	existing	leakage-free level + periodicity + quality
apf_max, apf_p95	peakvar -- magnitude	existing	level / loudness of churn
apf_cov, peak2med, duty_gt05	peakvar -- scale-invariant	existing	shape / burstiness (unitless)
wr_rate, rd_rate, rd_frac	disk (Plan 06)	existing	host-side disk read/write behaviour
APF (changed-page fraction)	Hamming -- baseline	kept	the existing signal, retained for comparison
Hamming sum	Hamming -- NEW	additive	total bits flipped per snapshot
mean Hamming / changed page	Hamming -- NEW	additive	intensity per touched page -- the encryption tell
p95 / max Hamming per page	Hamming -- NEW	additive	is any page heavily rewritten

Feature inventory. The new per-page Hamming scalars are computed additively at capture (XOR + popcount in the page comparison APF already performs) -- a few scalars, no per-page storage.

Why the new metric, concretely

APF asks only 'did this page change (yes/no)'. A stealth encryptor changes few pages (low APF, looks quiet) but fully encrypts each one (~half its bits flip). mean-Hamming-per-changed-page stays high even when the page count is low -- it can see what APF cannot. It is stored next to APF (the baseline) so the comparison is built in, and it costs a few scalars per snapshot, not per-page storage.

7. Tests: what we have and what to capture

The existing dataset is 11 workloads across 5 families. The families are small and uneven in their number of distinct workloads, and that -- not the cell count -- is the binding constraint on the per-family work.

Family	Kind	Distinct workloads	Cells	Per-family block validatable now?
ransomware	threat	4	24	Yes -- 4 within-family folds
mem_sweep	benign	3	18	Marginal -- 3 folds (pilot-grade)
mem_fault	benign	2	12	No -- 1 degenerate fold
app	benign	1	6	No -- family-of-one (memorises one workload)
scanner	threat	1	6	No -- family-of-one; and a threat family

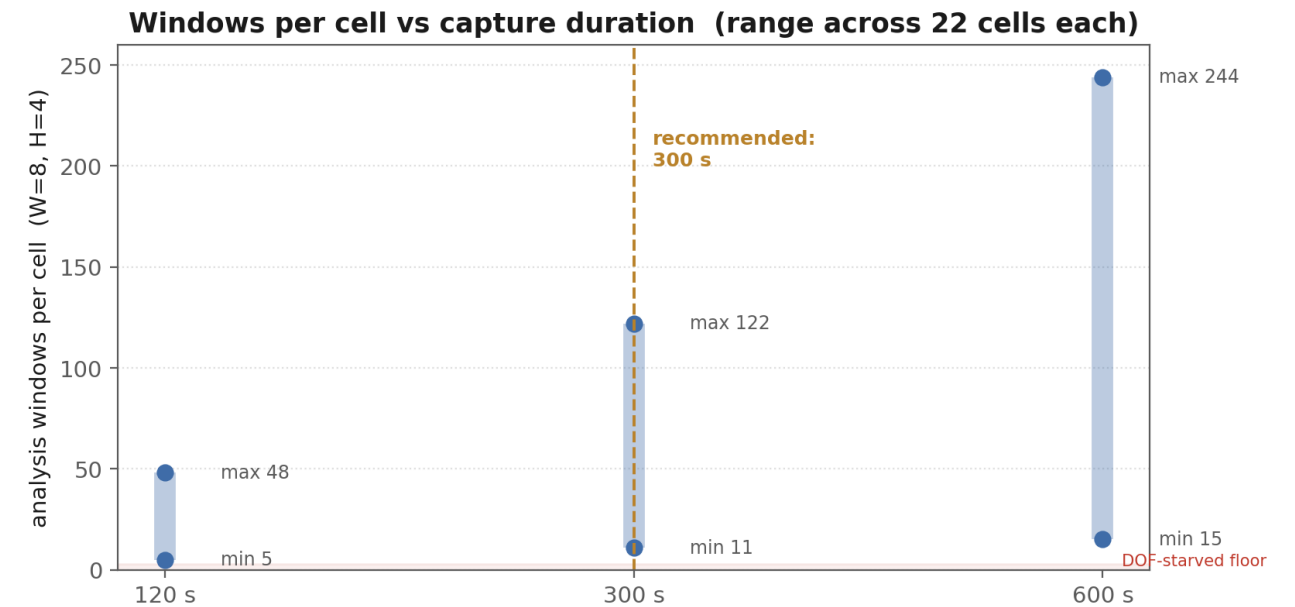
Family composition of the existing 66-cell dataset. Size, in distinct workloads, decides whether a per-family model can be honestly validated.

Because server access is available, we expand the thin families. The priority is **distinct workloads** (which test generalization), with repetitions as a secondary axis (which estimate variance, and matter because the signal is stochastic). Critically, the executables for most needed workloads **already exist**: app can grow from 1 to 6 by capture alone, with no new code; only scanner -- a threat family -- needs new programs written.

Family	Have	Target	Add	Path	Source
app	1	>= 3 (up to 6)	+5	capture only (no code)	existing app_sqlite_oltp / sqlite_analytical / gzip_compress / gzip_decompress / json_parse
scanner	1	>= 3	+2	author new code, then capture	two new scanner-behaviour programs
mem_fault	2	>= 3	+1	author or treat variants as distinct	judgment call
ransomware	4	ok	--	already sufficient	--
mem_sweep	3	ok	--	already sufficient	--

Capture plan to lift every family to a validatable size. app is fixed by pure capture (executables exist); only scanner needs new code.

On duration: even 120 s already clears the analysis-window floor, so short captures are viable. We recommend **300 s** as the working length (a good window yield at half the cost of 600 s), and we will confirm the true minimum offline by **truncating** existing 600 s traces before committing capture time.



Windows per cell versus capture duration (measured). Even the shortest duration clears the starvation floor; 300 s is the recommended balance.

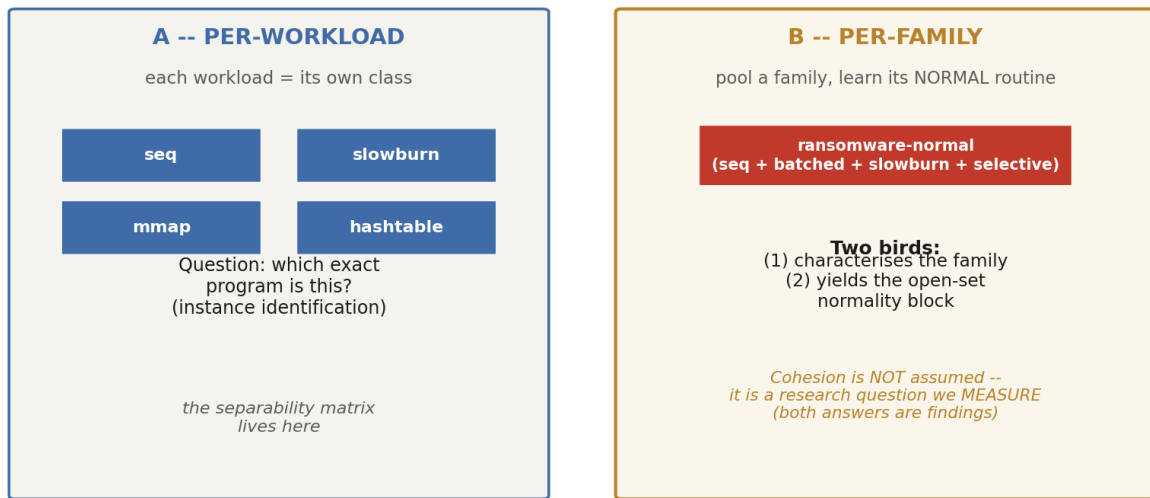
Duration	Windows per cell (range, W=8/H=4)	Note
120 s	5 -- 48	already clears the DOF floor
300 s	11 -- 122	recommended -- balances window count vs server time
600 s	15 -- 244	most windows, but twice the capture time

Window yield by duration, measured across the existing cells.

8. Two modelling paths

Two distinct, complementary modelling paths run in parallel. They are not competitors.

Two parallel modelling paths



schematic

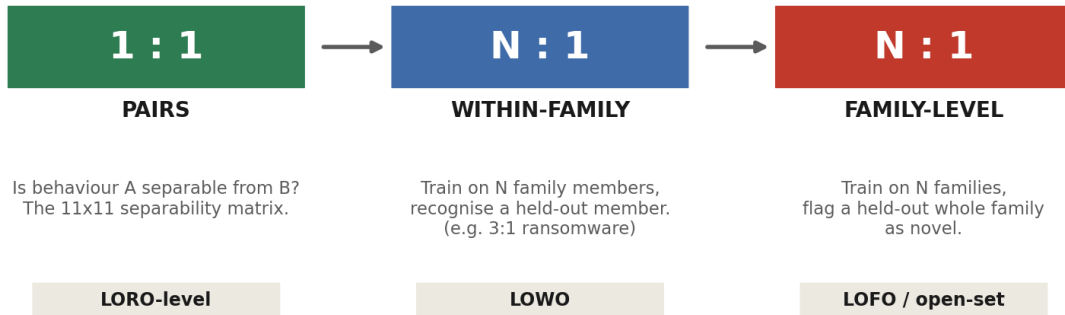
The per-workload path (instance identification) and the per-family path (learn a family's normal routine). The per-family path both characterises the family and yields an open-set normality model.

Cohesion is a research question, not an assumption. Pooling a family 'as one' only describes it well if its workloads resemble each other -- and whether they do is itself a finding (RQ3). If a family is cohesive, its label maps to a real shared memory signature. If it is not (an early data point: ransomware's leave-one-family-out recall was only 0.25), then the semantic family does **not** correspond to a single memory routine, which is a stronger and more interesting result -- it forces sub-family granularity. We quantify cohesion as a number (a between-family / within-family ratio plus within-family generalization) and also test it without labels: does clustering the memory signal recover the families we imposed?

9. The separability ladder

Separability is examined as a ladder of increasing difficulty. The master artifact is a **workload-level separability matrix ordered by family** -- the family-level view is derivable from it by averaging blocks, but not vice versa.

The separability ladder: from 'are they different' to 'does it generalise'



harder, more honest ->

schematic

From 1:1 pairs (are two behaviours separable) up through N:1 crosses (does a group generalize to a held-out member / family). The N:1 rungs are exactly the leave-one-out generalization tests.



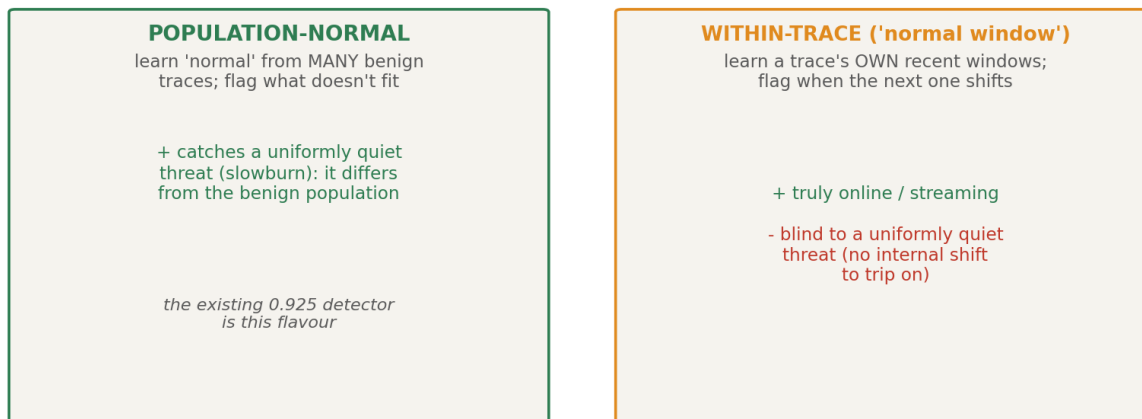
The master artifact (schematic). Diagonal blocks measure within-family cohesion; off-diagonal blocks measure between-family separation; a cross-family low cell (green) is a masquerade. Run three times -- magnitude, scale-invariant, and combined -- to map which feature type resolves which pair.

A caution carried from the metrics section: per-trace normalization removes the absolute level, but it was the **level** that separated slowburn from pagefault. So magnitude and shape are likely **complementary** -- each resolves different pairs -- and the matrix is the instrument that shows, pair by pair, where each matters.

10. Two detector flavours, and the bake-off

Within the detection work, two flavours of novelty detector answer different questions.

Two detector flavours (open-set / novelty)



schematic

Population-normal (learn normal from many benign traces) versus within-trace (learn a trace's own recent windows and flag a shift). The first can catch a uniformly quiet threat; the second is truly online but blind to one.

There is also an unresolved mechanism question for the per-family path, to be settled **empirically** rather than by argument: the **per-family one-class bank** (one density model per family) versus a **discriminative family classifier with a reject option** (open-set with two thresholds rather than five blocks). At the current sample size the two may be statistically indistinguishable, so the pilot runs **both on the same folds** and lets the data decide.

The sharp failure mode to guard against

The per-family rule 'clear it if it matches a known benign family' can launder the stealth threat: slowburn (low APF) is closest to a benign family in a magnitude-driven space, so a benign block would clear it. Guard: run the pilot on magnitude-invariant shape features (apf_cov, peak2med, duty_gt05) and hold slowburn out as a probe, with its recall on the headline table so it can never hide in an average.

11. Methodology and statistical protocol

The design's credibility rests on a few non-negotiable rules drawn from the review.

- **Leak-free fitting.** The imputer, scaler, and any operating-point threshold are fit **inside each fold** on training-benign only. No global fit survives for any threshold/PR metric (the committed code fits these globally -- valid for ROC ranking, but a leak for an operating point).
- **Honest units.** Bootstrap confidence intervals resample whole **workloads** (11) for LOWO/detection claims and **families** (6) for LOFO; the (workload, duration) cluster bootstrap is a labelled sensitivity bound only, never the headline CI.
- **Significance by permutation/exact tests**, computed at the generalization unit -- not asymptotic tests, given $n \leq 11$.

- **A regression anchor.** Reproduce the committed 0.925 / 0.933 before changing anything, then show what each fix moves.

A structural limit must be stated honestly: with few independent units, some comparisons **cannot** reach significance regardless of the effect. These are reported descriptively, with confidence intervals, and never dressed up with a p-value.

Independent units n	Sign / McNemar floor $p = 2^{-(1-n)}$	Can reach $p < 0.05$?
4 (disk-LOFO)	0.125	No, ever
5	0.0625	No, ever
6 (LOFO)	0.031	Only if all 6 agree, no ties
11 (LOWO)	0.00098	Yes (needs ≥ 6 concordant)

Structural significance floor. With few independent units, some claims cannot reach significance regardless of effect size -- they are reported descriptively, with CIs.

Accordingly, claims are sorted into three tiers: a small set of **confirmatory** hypotheses (the one-class detector vs a permutation null, the slowburn/pagefault separability, the supervised binary vs the prior) corrected together with Holm; **descriptive** results (all leave-one-family-out comparisons, 'disk hurts detection', 'family beats prior') reported as intervals with no significance verdict; and **effect-size-only** results (the masquerade separation magnitude). The false-positive benefit of the per-family scheme is, on current data, demonstrable only as a worked mechanism -- with at most ~5 honest novel-benign test points, its exact-McNemar floor is 0.0625, so it cannot reach significance until the families grow.

12. Expected results

Each experiment is designed so that both outcomes advance the thesis. The table states, per experiment, what would confirm versus refute -- and what each means.

Experiment	CONFIRM (and its meaning)	REFUTE (and its meaning)
1c separability (slowburn vs pagefault, memory alone)	AUC ~ 1.0, exact test $p < 0.0167$ -> Finding #2 rewritten: separable in memory; the supervised setup failed, not the signal	AUC ~ 0.5 out-of-sample -> memory aliasing is real; disk genuinely required
1d kill-test (benign-floor learning curve)	AUC degrades gracefully as benign workloads leave training -> detector learns a manifold; green-light	AUC collapses when one benign workload (esp. pagefault) leaves -> memorisation of 6 points; stop
1a fused detector (one-class, PR-AUC, leak-free threshold)	PR-AUC CI above prevalence under LOFO-benign -> a real weak-positive detector with an operating point	PR-AUC CI straddles prevalence -> the 0.93 was a ROC/prevalence illusion; the negative is hardened with CIs
per-family pilot (ransomware $n=4$, mem_sweep $n=3$)	held-out family member accepted, other family rejected -> family-normal generalises; cohesion measured	within-family rejection or cross-family acceptance -> family label does not map to one memory routine (a finding)

Every experiment is win/win: both outcomes are reportable, and several can rewrite the thesis spine.

Why this is win/win

If the detector survives confidence intervals and the benign-floor kill-test, the spine upgrades to a positive, mechanistic claim that also *explains* the old negative as a small-sample estimator artifact. If it collapses, the negative is hardened with proper error bars and the true limiter (benign diversity at $n=11$) is named -- which also redirects scarce server time correctly. Neither path is a dead end.

13. Risks and honest scope

- **Small n.** 11 workloads / 5 families bound what any analysis can claim; several current 'findings' are descriptive, not significant, by construction.
- **Synthetic workloads.** External validity to real malware is untested; this is a controlled study of behaviour classes, not a field detector.
- **Capture-environment confound.** New captures must use the same host configuration as the original 66, or family identity could entangle with capture conditions.
- **Cohesion may be low.** The per-family path may show that families are not cohesive in memory -- reported as a finding, not hidden.
- **Per-page spatial detail is not retained.** The new Hamming scalars keep aggregate magnitude, not which pages changed; a future spatial analysis would need a richer capture.

The plan is deliberately staged so that the expensive, irreversible step (server capture) is the last one, and is taken only after the cheap, offline steps have shown it is worth taking.